Incident Response & SOC Analysis Report
Incident Type: Credential Compromise & Suspicious Outbound Traffic
Prepared By: Dharmik Niteenbhai Poshiya (Cyber Security Intern)
Date: 17 October 2026

1. Executive Summary:
On 17 October 2026, the Security Operations Center (SOC) detected a series of anomalous activities originating from an employee's workstation. The incident began with multiple failed login attempts against the corporate VPN, followed by a successful login from an unrecognized geographic location. Subsequently, Endpoint Detection and Response (EDR) solutions flagged a malware execution alert, and firewall logs recorded suspicious outbound network traffic. The SOC team successfully isolated the host, eradicated the malware, and restored the system without any data breach or lateral movement.

2. Incident Timeline (Chronology of Events):
09:15 AM: SIEM (Splunk) triggers an alert for 50+ failed login attempts (Brute Force) on the corporate VPN gateway targeting the user account jsmith.

09:35 AM: Successful VPN login recorded for jsmith from an anomalous IP address outside the operating country.

10:05 AM: EDR (CrowdStrike Falcon) triggers a high-severity alert indicating the execution of a suspicious payload named update_patch.exe on the jsmith-Workstation.

10:15 AM: Firewall logs (Palo Alto Networks) detect unusual outbound network traffic from jsmith-Workstation to an unknown external IP address over port 443 (suspected Command and Control - C2 communication).

10:20 AM: SOC Analyst (Dharmik Poshiya) acknowledges the alerts and begins the incident response protocol.

3. Incident Identification & Classification:
Incident Category: Unauthorized Access & Malware Infection.

Detection Sources:

SIEM (Splunk / VPN Logs): Brute force detection and anomalous login.

EDR (CrowdStrike): Malware payload detection.

Network Firewall (Palo Alto): Suspicious outbound C2 traffic.

Root Cause Analysis (Preliminary): The attacker successfully brute-forced a weak VPN password (due to a lack of Multi-Factor Authentication) and deployed a malware payload to establish a reverse shell (C2 beaconing) for further exploitation.

4. Containment Strategy:
The immediate priority of the SOC team was to halt the attack progression and prevent lateral movement across the internal network.

Endpoint Isolation: Using CrowdStrike Falcon EDR, the compromised machine (jsmith-Workstation) was immediately placed into "Network Containment." This severed its connection to the corporate network while maintaining a secure channel to the CrowdStrike console for forensic investigation.

Network Blocking: The malicious external IP address associated with the Command & Control (C2) traffic was blacklisted globally on the Palo Alto Networks Next-Generation Firewall (NGFW).

Account Suspension: The compromised user account (jsmith) was temporarily disabled in Microsoft Active Directory to prevent further unauthorized VPN or

internal portal access. Active sessions were forcefully terminated.

5. Eradication & Recovery:
Once the threat was successfully contained, the team proceeded to remove the malicious artifacts and restore normal operations.

Malware Removal: The malicious executable (update_patch.exe) and its associated registry persistence keys were quarantined and deleted remotely via the CrowdStrike response shell.

System Integrity Check: A full deep scan was initiated on the workstation to ensure no dormant malicious files remained.

Credential Reset: A mandatory password reset was enforced for the jsmith account requiring strong complexity.

Restoration: Upon verification of a clean state, the network containment was lifted from the workstation, and the user was securely re-onboarded.

6. Lessons Learned & Preventive Action Plan:
To prevent similar incidents from occurring in the future, the following architectural and policy changes are recommended:

Enforce Multi-Factor Authentication (MFA): Implement MFA (e.g., Okta or Duo Security) for all external-facing services, particularly the corporate VPN. This would have completely neutralized the brute-force attack.

Tune SIEM Alerting: Refine Splunk correlation rules to trigger high-priority alerts earlier (e.g., after 10 failed login attempts within 5 minutes) rather than waiting for 50+ attempts.

Geo-Blocking: Configure the Palo Alto Firewall and VPN gateway to block authentication attempts from geographic regions where the company does not operate.

Endpoint Execution Prevention: Update CrowdStrike policies to strictly block the execution of unsigned binaries downloaded from the internet without prior hash approval.